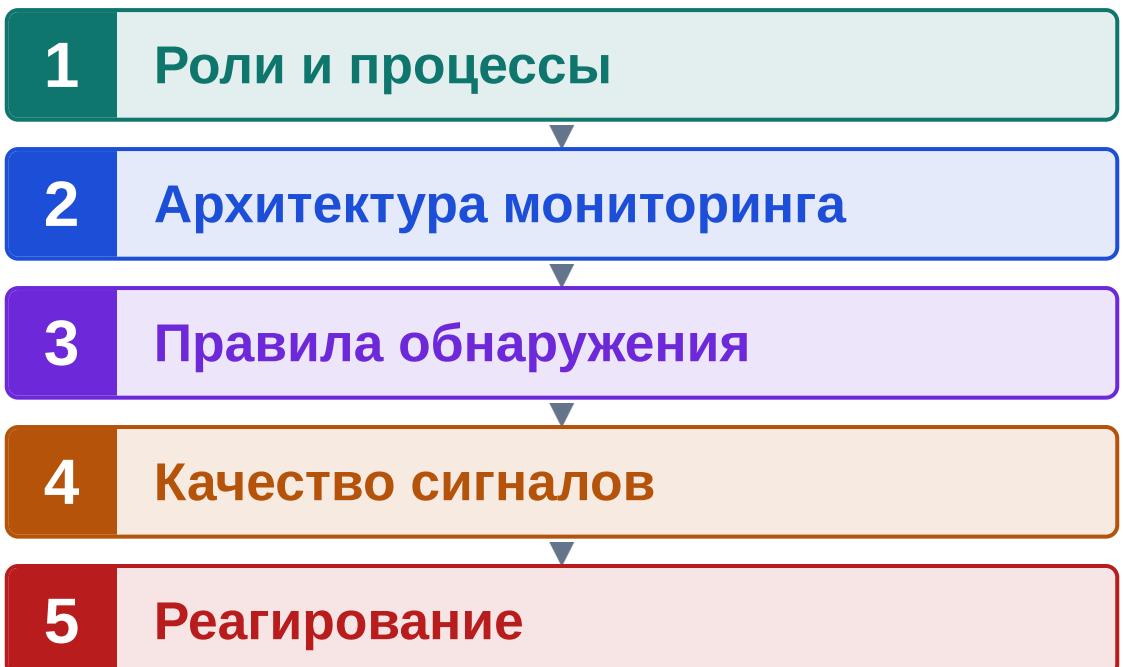
Лекция 2

Архитектура мониторинга и реагирования

Роли · уровни мониторинга · качество сигналов · ложные срабатывания

План лекции


1
Роли и процессы
2
Архитектура мониторинга
3
Правила обнаружения
4
Качество сигналов
5
Реагирование

Событие, сигнал, инцидент

Событие

любое наблюдаемое явление в системе или сети

Сигнал

уведомление о конкретной атаке: сработало правило

Инцидент

происшествие, угрожающее конфиденциальности, целостности или доступности

Событий много, сигналов мало, инцидентов ещё меньше

Сквозная ситуация: подбор пароля

Время	Адрес	Запись	Итог
09:00:04	203.0.113.7	anna	неудача
09:00:31	203.0.113.7	anna	неудача
09:01:02	203.0.113.7	anna	неудача
09:01:35	203.0.113.7	anna	неудача
09:02:10	203.0.113.7	anna	неудача
09:03:12	203.0.113.7	anna	успех

→

Сигнал
5 неудач за 10 минут, затем успешный вход

Инцидент?
учётная запись anna, вероятно, захвачена

1

Роли и процессы

кто и по какому порядку разбирает сигналы

Пять функций центра мониторинга



Результаты разбора возвращаются в правила и процессы

Уровни аналитиков

Уровень 1

Аналитик первой линии

разбор сигналов: подтвердить, отклонить, передать выше

Уровень 2

Аналитик расследования

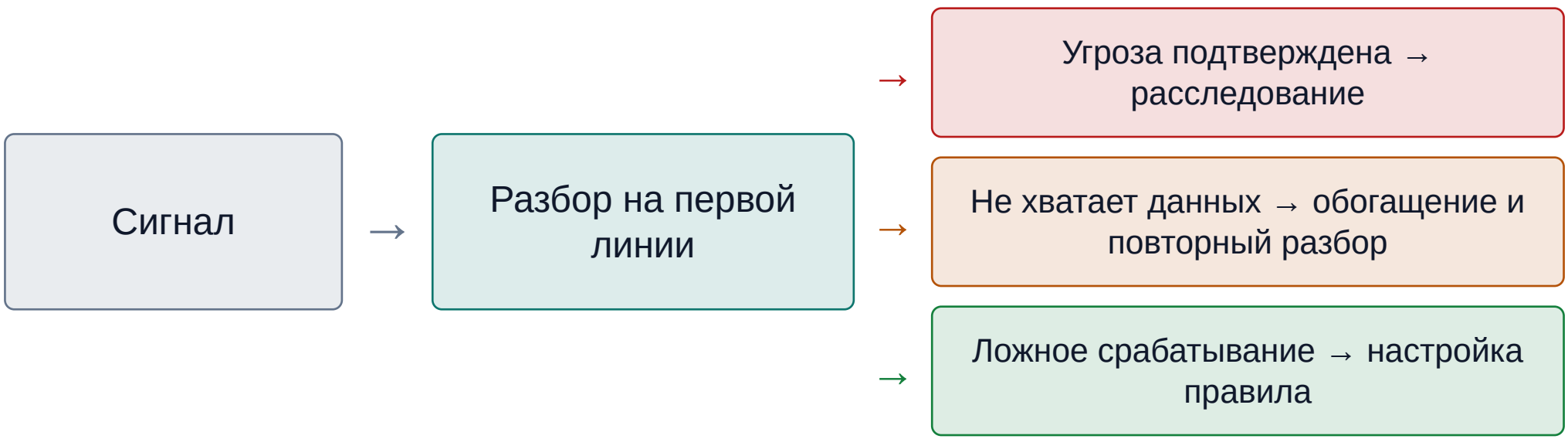
глубокий анализ, корреляция, локализация и устранение

Уровень 3

Инженер по обнаружению, охотник за угрозами

разработка и настройка правил, поиск угроз без сигналов

Решения при разборе сигнала



Регламент разбора: подбор пароля

1
Адрес

внутренний или внешний?

2
Неудачи

сколько попыток, за какое время?

3
Учётная запись

служебная, администратор, обычная?

4
Успех после неудач

если да — сразу на второй уровень

Показатели работы центра

Показатель	Что измеряет	Как читать
Сигналов на аналитика	Нагрузка	Рост без роста штата — пропуски
Доля сигналов вверх	Нужда в глубоком анализе	Мала — не справляется; велика — шумят правила
Время до разбора	Скорость реакции	Растёт при перегрузке
От атаки до обнаружения	Видимость	Главный показатель обнаружения
От обнаружения до устранения	Скорость реагирования	Зрелость процесса

2

Архитектура мониторинга

откуда и как поступают данные

Уровни мониторинга

Сетевой

сканирование, внешние связи, вывод данных

Узла

запуск программ, закрепление в системе

Приложения

входы, обращения к данным, отказы в доступе

Учётных записей

входы, смена прав, второй фактор

Облака

создание ресурсов, изменение политик доступа

Что видно на каждом уровне

Уровень	Видно	Не видно
Сетевой	Сканирование, внешние адреса	Содержимое шифрованного обмена
Узла	Запуск процессов	Действия на других узлах
Приложения	Входы, обращения к данным	Атаки, не дошедшие до приложения
Учётных записей	Входы, смена прав	Что происходит после входа
Облака	Изменение политик доступа	Внутренности управляемых служб

> Ни один уровень не показывает всей картины

Поток данных в системе мониторинга



Компоненты системы мониторинга

Компонент	Функция	Примеры
Сбор	Чтение журналов на источнике	Fluent Bit, Filebeat, auditd
Доставка	Передача с буферизацией	Kafka, Vector, Logstash
Нормализация	Единая схема	ECS, OCSF
Хранение и обнаружение	Поиск, применение правил	OpenSearch, Wazuh, ClickHouse
Управление сигналами	Очередь, карточки	TheHive
Автоматизация	Сценарии реагирования	Shuffle, Cortex

Пример: Elastic Stack

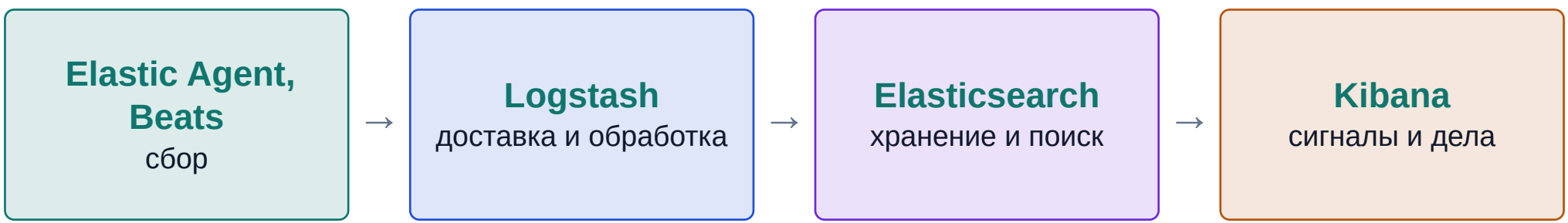


Схема **ECS**: единые имена полей

Elastic Security: правила, сигналы, дела

Нормализация: единая схема события

Разные источники

```
Mar 12 09:00:04 sshd: Failed
password for anna from 203.0.113.7
```

```
{"user":"anna","ok":false}
```

→

Поле	Значение	В ECS
timestamp	2026-03-12T09:00:04Z	`@timestamp`
event_type	auth.login	`event.category`
actor.id	anna	`user.name`
source_ip	203.0.113.7	`source.ip`
outcome	failure	`event.outcome`

Одна схема — одно правило для всех источников

Обогащение: насколько это важно

Контекст актива	Расположение	Репутация	Учётная запись
рабочий сервер, критичность высокая	страна, не типичная для пользователя	адрес известен подбором паролей	принадлежит бухгалтеру

Контекст повышает или понижает важность сигнала

Данные об угрозах

Стратегический	Тактический	Оперативный	Технический
мотивация нарушителей, тенденции	приёмы и кампании нарушителей	сведения о текущих кампаниях	индикаторы: адреса, домены, хеши
для: руководство	для: инженеры по обнаружению	для: группа реагирования	для: системы обнаружения и защиты

STIX — формат описания сведений: объекты и связи → **TAXII** — протокол обмена этими объектами по HTTPS

3

Правила обнаружения

как описать атаку правилом

Пример 1: подбор пароля

```yaml
title: Подбор пароля к учётной записи
name: failed_login_burst
correlation:
    type: event_count
    rules: [failed_login]
    group-by: [actor.id]
    timespan: 10m
    condition: {gte: 5}
```

rules считаем неудачи

group-by отдельно по записям

timespan в окне 10 минут

condition пять и более

5 неудач anna, 09:00:04–09:02:10 → базовое правило отбирает неудачи → подсчёт по записи за 10 минут: 5 → 5 ≥ 5: сигнал в 09:02:10

Пример 2: вход после серии неудач

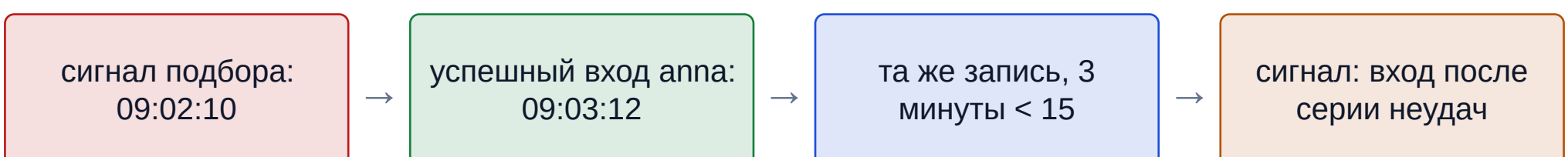
```
title: Успешный вход после серии неудач
correlation:
    type: temporal_ordered
    rules: [failed_login_burst,
            successful_login]
    group-by: [actor.id]
    timespan: 15m
```

temporal_ordered строгий порядок

rules подбор, затем вход

group-by одна запись

timespan в пределах 15 минут



Те же правила в Elastic Security

Sigma	Elastic Security	Параметры
event_count	Правило «порог»	группировка по user.name, порог 5
value_count	«Порог» с числом значений	source.ip, не менее 8 разных user.name
temporal_ordered	Корреляция событий (EQL)	последовательность за 15 минут

```
sequence by user.name with maxspan=15m
  [ authentication where event.outcome == "failure" ] with runs=5
  [ authentication where event.outcome == "success" ]
```

Типы корреляции в Sigma

event_count

число событий за период

value_count

число различных значений поля

temporal

события за период в любом порядке

temporal_ordered

события в заданном порядке

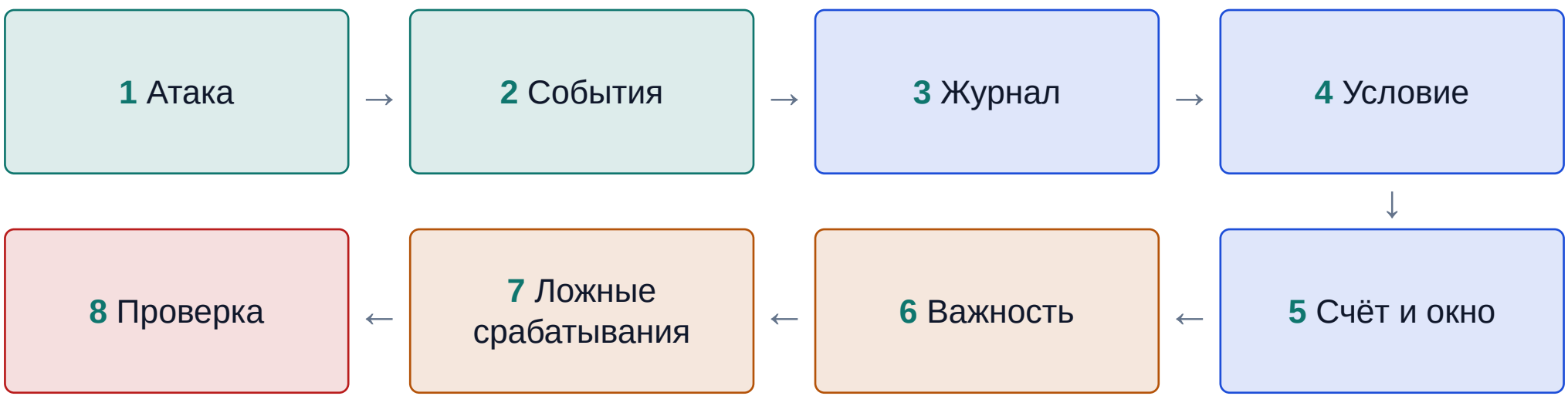
Окна времени



Порог: 3 события за 5 минут.
Неперекрывающиеся окна — сигнала нет

Скользящее окно — сигнал формируется

Восемь шагов создания правила



Сложение слабых сигналов

Слабый сигнал	Баллы	ATT&CK
Более трёх неудачных входов	2	T1110
Вход из новой страны	2	T1078
Успешный вход после неудач	3	T1110
Обращение к административному интерфейсу	1	T1078
Выгрузка более 1000 записей	3	T1041

> Сумма за 30 минут не меньше 8 — один сильный сигнал «вероятный захват записи»

4

Качество сигналов

насколько можно доверять

Четыре исхода работы правила

	Атака была	Атаки не было
Сигнал есть	**TP** верное срабатывание	**FP** ложное срабатывание
Сигнала нет	**FN** пропуск атаки	**TN** верное молчание

Точность и полнота

Точность (Precision)

TP / (TP + FP)

доля верных сигналов среди всех

Полнота (Recall)

TP / (TP + FN)

доля найденных атак среди всех

40

сигналов

30

верных (TP)

50

атак за период

Precision = 30 / 40 = 0,75 · Recall = 30 / 50 = 0,6

Порог: компромисс

Порог ниже	Порог выше
Полнота ↑ · точность ↓ больше ложных срабатываний	Точность ↑ · полнота ↓ больше пропусков

Перегрузка аналитика сигналами

Общие правила	Нет контекста	Нет нормы	Дубли
срабатывают на обычное поведение	неясно, критичен ли актив	любое отклонение подозрительно	одна атака — много сигналов

Много ложных сигналов — аналитик пропускает настоящие

Способы снижения ложных срабатываний

Способ	Суть	Пример
Настройка	Поднять порог, исключения	Порог 5 → 10
Обогащение	Контекст актива, репутация	Для рабочих серверов — выше важность
Корреляция	Объединить слабые сигналы	Баллы за несколько признаков
Подавление	Временно не сигналить	Известный сканер, с датой пересмотра
Уровни уведомления	Малозначимое — в панель	Информационные сигналы без уведомлений

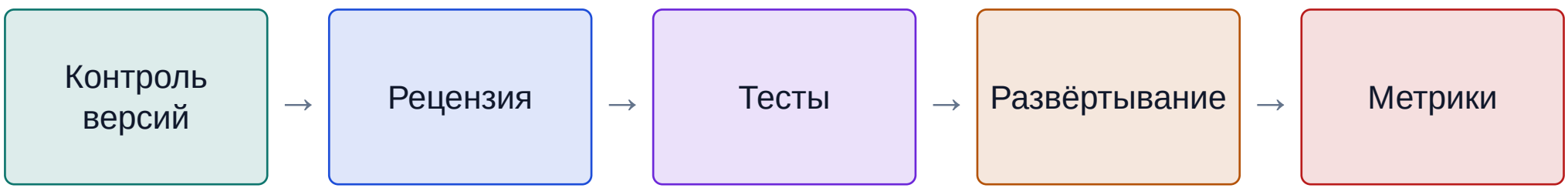
Пример: общий адрес офиса

Проблема
много сотрудников ошибаются при входе с одного адреса — правило «5 неудач» срабатывает каждый день

→

Решение
исключить шлюзы или считать неудачи по паре «адрес и учётная запись»

Обнаружение как код



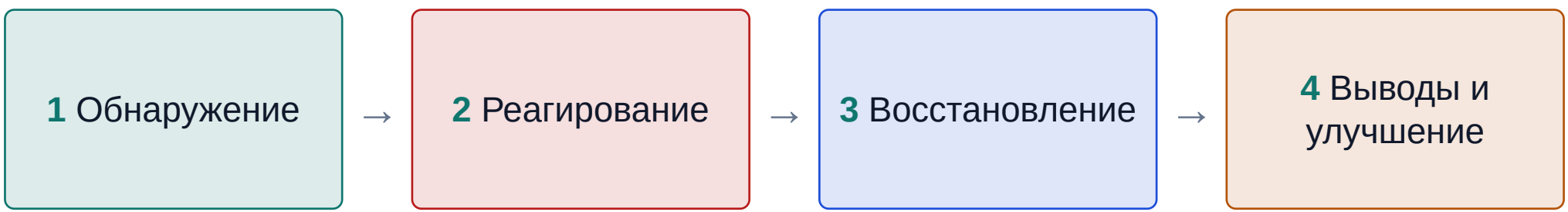
Шаблон ADS: цель, данные, логика, ложные срабатывания, проверка, реагирование

5

Реагирование

что делать после подтверждения

Цикл реагирования



NIST SP 800-61 Rev. 3 опирается на функции CSF 2.0

Автоматизация и риск действия

Заблокировать адрес
риск низкий

выполняется сразу

Заблокировать учётную запись
риск средний

с уведомлением и возможностью отмены

Изолировать узел, отключить сервис
риск высокий

только с одобрения человека

Чем выше риск действия, тем больше участия человека

Сценарий для сквозной ситуации



Выводы: настроить правило, включить второй фактор

Главное

1 Роли и процессы	Три уровня; три решения при разборе
2 Архитектура	Несколько уровней, единая схема, обогащение
3 Правила	Sigma, скользящие окна, сложение сигналов
4 Качество	Precision и Recall, борьба с перегрузкой
5 Реагирование	Цикл и автоматизация по риску

Лекция 2

Архитектура мониторинга и реагирования

Роли · уровни мониторинга · качество сигналов · ложные срабатывания